

Analysis Exercise

Joseph J. Patnoe

Department of Cyber, Intelligence, and Information Operations, The University of Arizona

CYBV 435: Cyber Threat Intelligence

Professor Ryan Roberts

7 October 2025

Background

Hitchcock Avia's intrusion detection system (IDS) alerted on data exfiltration from the machine of senior engineer Melanie Daniels, who works on the unmanned aerial vehicle (UAV) guidance system. The compromise originated from a spear-phishing email with the subject line *AirHammett Job Opportunitees*. The attached file, *Available_Postions.pdf*, when opened, downloaded **edg32.dll** from <http://www.hedren.com/edg32.dll>. The malware created an encrypted HTTPS channel from port 8352 on the victim's host to port 1913 on command-and-control (C2) infrastructure at IP **104.151.248.173**, hosted on a compromised aviation company server.

Based on Mandiant/FireEye threat intelligence, six APT groups are most active against the aerospace and defense industry and thus represent the primary candidates for this intrusion:

1. **APT3 (UPS Team, China)** – Highly sophisticated; frequent exploitation of Adobe Flash zero-days; long history of targeting aerospace and defense sectors.
2. **APT4 (Maverick Panda / Sykipot Group, China)** – Regularly targets the defense industrial base (DIB) and aerospace via Department of Defense-themed spear phishing.
3. **APT5 (China)** – Focused on high-tech manufacturing and military application technology; documented interest in unmanned aerial vehicles.
4. **APT10 (Menupass Team, China)** – Longstanding espionage against construction, engineering, and aerospace, often leveraging supply-chain and managed service provider access.
5. **APT18 (Wekby, China)** – Known to weaponize Adobe Flash Player vulnerabilities, including CVE-2015-5119; targets aerospace and defense.

6. **APT37 (ScarCruft, North Korea)** – State-sponsored DPRK actor; specializes in espionage against South Korean aerospace/defense; uses recruitment-themed phishing and Flash exploits; compiles malware in UTC + 8:30.

APT37 (ScarCruft) is the most likely group to have conducted this intrusion.

Key Assumptions

1. **The Flash exploit is CVE-2015-5119.**
 - If this is misidentified and the vulnerability differs, attribution may shift to another actor.
2. **Compile time (UTC + 8:30) is genuine.**
 - North Korean developers operate in this time zone; if falsified, China-based APTs (APT3 or APT18) become more plausible.
3. **Observed spear-phishing infrastructure (hedren.com and C2 104.151.248.173) has not yet been publicly tied to any specific actor.**
 - If infrastructure overlaps appear in Mandiant feeds linking directly to a Chinese group, the hypothesis could change.

Analysis of Competing Hypotheses (ACH)

Evidence/Indicator	APT3	APT4	APT5	APT10	APT18	APT37
Focus in Aerospace	✓	✓	✓✓	✓	✓	✓✓
Spear-phish w/ job lure	✓	✓	●	✓	✓	✓✓
CVE-2015-5119 exploit	✓✓	×	×	×	✓✓	✓✓
Time Zone = UTC + 8:30	×	×	×	×	×	✓✓
South Korea targeting	●	×	×	×	●	✓✓

✓✓ = **Strongly/Diagnostically Consistent**

✓ = **Consistent but Not Diagnostic**

✗ = **Inconsistent**

ACH outcome:

- **APT37** fits *all* major indicators (ROK aerospace focus, CVE-2015-5119, UTC +8:30, job lure, exfiltration malware).
- **APT3/APT18** explain the Flash exploit and sector but fail on compile timezone and South Korea focus.
- **APT5** matches UAV interest but lacks Flash 5119 history and North Korean time zone.
- **APT4/APT10** fit sector but lack diagnostic exploit and time-zone linkage.

Relative likelihood:

- **APT37 – 65% (High confidence)**
- APT3 – 15%
- APT18 – 10%
- APT5 – 5%
- APT4 – 3%
- APT10 – 2%

Confidence Level

High confidence (~65%) that **APT37** is responsible. Remaining uncertainty centers on whether the **UTC + 8:30** compile time is genuine or spoofed.

Information Needed to Confirm or Refute

- **Malware reverse engineering:** Verify if edg32.dll shares ScarCruft/ROKRAT code traits (PDB paths, encryption routines, command set).
- **Exploit fingerprinting:** Extract and analyze the embedded SWF/Flash object to match known APT37 CVE-2015-5119 kits.
- **Infrastructure analysis:** TLS certificates, JA3 fingerprints, WHOIS/registrar data for hedren[.]com and 104.151.248.173.
- **Regional threat correlation:** Check whether other South Korean aerospace firms were simultaneously hit with similar lures/C2.
- **Language and resource artifacts:** Korean-language strings or decoys would further support DPRK attribution.